

Telnet — Terminal Network Protocol

Servicio

Telnet

Puerto por defecto

23/TCP

Descripción

Telnet es un protocolo de red desarrollado en 1969 que proporciona acceso de terminal remoto bidireccional orientado a texto a través de conexiones TCP. Estandarizado en RFC 854 (1983), fue ampliamente utilizado para administración remota de sistemas antes del surgimiento de SSH. **No implementa ningún tipo de cifrado**, por lo que toda la comunicación, incluyendo credenciales, se transmite en texto plano. Hoy en día se considera obsoleto e inseguro para cualquier uso de producción.

Riesgos de seguridad

- **Credenciales en texto plano:** Usuario, contraseña y toda la sesión son legibles por cualquier actor que capture el tráfico.
- **Intercepción de tráfico (sniffing):** Sin cifrado, la sesión completa puede ser capturada y reproducida.
- **Ataques Man-in-the-Middle (MITM):** Sin autenticación del servidor, un atacante puede insertar comandos en la sesión.
- **Ausencia de autenticación mutua:** El cliente no puede verificar la identidad del servidor.
- **Fuerza bruta:** No existen mecanismos estándar de bloqueo de intentos fallidos en la especificación original.
- **Exposición de datos sensibles:** Cualquier información procesada durante la sesión (rutas, archivos, comandos ejecutados) queda expuesta.

Escenarios de ataque

1. **Captura de sesión completa:** Con Wireshark o tcpdump, un atacante en la misma red LAN o con acceso al switch captura la sesión Telnet e identifica credenciales, comandos ejecutados y salida del sistema.
2. **ARP Spoofing + Telnet sniffing:** El atacante se posiciona como intermediario mediante ARP poisoning y registra toda la actividad de administración remota.
3. **Session hijacking:** Herramientas como Hunt permiten inyectar comandos en una sesión Telnet activa secuestrando el número de secuencia TCP.
4. **Fuerza bruta:** Servicios Telnet expuestos en Internet son objetivos frecuentes de bots que

prueban contraseñas por defecto (especialmente en dispositivos IoT y routers).

Mitigaciones recomendadas

- **Deshabilitar Telnet completamente** y reemplazarlo por **SSH** (puerto 22).
- Si Telnet es estrictamente necesario (ej. dispositivos legacy sin soporte SSH), aislarlo en una VLAN de gestión sin acceso a Internet.
- Aplicar reglas de firewall que bloqueen el puerto 23 desde redes no confiables.
- Usar VPN para cualquier acceso remoto de administración antes de permitir Telnet en redes internas.
- Auditar activamente los dispositivos de la red en busca de servicios Telnet habilitados con escáneres como Nmap.
- En dispositivos IoT/embebidos, actualizar firmware que ofrezca SSH o deshabilitar el acceso remoto innecesario.

Nivel de exposición

Alto

Referencias

- Postel, J. & Reynolds, J. *RFC 854 — Telnet Protocol Specification*. IETF, 1983.
<https://www.rfc-editor.org/rfc/rfc854>
- CISA. *Known Exploited Vulnerabilities & Secure Configuration Guidance*.
<https://www.cisa.gov>
- NIST. *Guide to General Server Security — SP 800-123*.
<https://csrc.nist.gov/publications/detail/sp/800-123/final>
- NSA/CISA. *Top 10 Cybersecurity Misconfigurations* (incluye uso de protocolos no cifrados). <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-278a>